

****Orientation on the Data Protection Authority's Decisions Regarding AULA****

Date: 15-01-2024

****Decision****

Public Authorities

Criticism

Serious Criticism

Order

Supervision / Self-Management Case

Processing Security

Fundamental Principles

Risk Assessment and Impact Analysis

The Data Protection Authority has made decisions in five supervisory cases regarding the processing security in AULA. The Data Protection Authority found reason to issue orders for the preparation of impact analyses in two of the cases. Additionally, the authority has expressed criticism and serious criticism in the cases.

Journal Number: 2023-420-0001.

****Summary****

The Data Protection Authority initiated supervision in the autumn of 2021 concerning the processing of personal data in the IT system AULA by a total of six selected municipalities. The supervision focused on compliance with the rules of the General Data Protection Regulation regarding processing security and impact analysis.

"When schools/childcare institutions and parents communicate via AULA, sensitive and confidential information about children is often involved. It is therefore important that municipalities take good care of the information in AULA. According to the General Data Protection Regulation, children are entitled to special protection," says Signe Vestergård, special consultant at the Data Protection Authority.

The Data Protection Authority has now made decisions in all cases except one, as this case contains some additional elements.

The supervisions are a continuation of the Data Protection Authority's previous supervision of Kombit A/S (hereafter KOMBIT) in December 2019. During that supervisory visit, the Data Protection Authority found that KOMBIT could not be considered a data controller for AULA under Article 4, No. 7 of the General Data Protection Regulation. At the supervisory meeting, the Data Protection Authority informed KOMBIT that KOMBIT should ensure that all municipalities were informed of their data responsibilities and that KOMBIT should provide all necessary materials and information to the municipalities in this regard.

The Data Protection Authority finds that the supervisory cases raise some general data protection legal issues across the municipalities, which can be better handled collectively rather than separately at the individual municipalities. Therefore, the Data Protection Authority has chosen to inform the Danish Municipalities' Association (KL), the Agency for IT and Learning, and Kombit A/S (hereafter KOMBIT) about the authority's decisions in these cases. At the same time, the Data Protection Authority has formulated some recommendations for further work on processing security in AULA.

Furthermore, the Data Protection Authority will provide the same recommendations in a letter to all municipalities in the country, where the authority will also inform about the decisions. The purpose of the information to the municipalities is to encourage them to consider whether the material gives rise to (further) assessments, etc., or to ensure the implementation of additional security measures regarding their processing of personal data in AULA.

****Impact Analysis****

Although the five municipalities use the same technical solution (AULA) for the same processing activities, they have had a markedly different approach to the issue of impact analyses.

All five municipalities have received criticism or serious criticism in the part of the cases concerning impact analysis. Two of the municipalities have received serious criticism for not having prepared an impact analysis. The Data Protection Authority has also issued these two municipalities an order to

prepare an impact analysis within three months.

The other three municipalities have prepared impact analyses. The Data Protection Authority has reviewed them and assessed that none of them meet all the minimum requirements for an impact analysis.

Additionally, the Data Protection Authority has examined the timing of the preparation of the impact analyses and taken into account that there has been uncertainty regarding the data responsibility for the processing of personal data in AULA. The municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data and the responsibility for conducting risk assessments and impact analyses lay with KOMBIT. However, the Data Protection Authority concluded during the supervisory visit to KOMBIT in December 2019 that KOMBIT cannot be considered a data controller.

All three municipalities prepared the impact analyses only long after clarity regarding the data responsibility for the processing of personal data in AULA had been established. Two of the municipalities even prepared the impact analyses only after the authority requested the material in connection with the initiation of the supervision, which is why the Data Protection Authority has expressed serious criticism towards these two municipalities. The Data Protection Authority has expressed criticism towards the third municipality.

****Risk Assessment****

All five municipalities have also received criticism or serious criticism regarding the part of the cases that concerns the municipalities' risk assessment. The criticism relates to the documentation requirement to demonstrate that they have identified and mitigated the risks that the processing of personal data in AULA poses to the individuals to whom the data relates, ensuring an appropriate level of security. Additionally, the criticism concerns the lack of identification and implementation of relevant measures to ensure an appropriate level of security.

The Data Protection Authority has expressed serious criticism of two of the municipalities for not having submitted actual risk assessments. One municipality stated in January 2023 that they had not yet completed the initial...

work to identify relevant measures that can be implemented to reduce the identified high risks associated with the processing of personal data in AULA. The other municipality referred to a number of appendices as documentation for the mitigating measures the municipality had taken to reduce the risk for the registered individuals. The remaining three municipalities have submitted risk assessments. However, the Data Protection Authority has criticized these municipalities for not sufficiently demonstrating that they have ensured an appropriate level of security.

Several municipalities have submitted material from KOMBIT, where a number of high risks associated with the use of AULA have been identified. The municipalities have responded differently to the material. Some municipalities have stated that they have adopted KOMBIT's risk assessment and have based their descriptions of the measures they have implemented to reduce these risks on it. One municipality indicates that they have reviewed the material from KOMBIT but concluded that it could not be immediately used as a basis for actual risk assessments. Other municipalities have conducted their own assessments, where some of the risks they identified are assessed to pose a lower risk than what is indicated in KOMBIT's material—however, without sufficiently documenting the basis for this assessment.

Risk of erroneous transmission in AULA

The Data Protection Authority has found that a large portion of the reports of breaches of personal data security in AULA that the authority receives concern erroneous transmission of personal data to one or more incorrect recipients in AULA. This is also a risk that several municipalities have identified in their risk assessments. Several of the municipalities have implemented organizational measures to inform users about this risk when sending messages via AULA. Additionally, one of the municipalities has also had a change request implemented in AULA, which allows for the deletion and editing of sent content in messages.

Despite these measures, the Data Protection Authority continues to receive a number of reports of

breaches from the municipalities concerning erroneous transmissions in AULA. It is generally the Data Protection Authority's view that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible to implement one or more technical measures to reduce the risk of erroneous transmission. They should also explore the possibilities of designing the messaging function in a way that minimizes such risk.

In a letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Authority has recommended that KOMBIT, together with the data-controlling municipalities, conduct such an investigation. This recommendation will also be reiterated in a letter to all municipalities in the country.

Joint impact assessment and code of conduct

It is the Data Protection Authority's view that the municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA. This is based on the fact that the municipalities use the same type of system for the same processing activities of the same type of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same supplier.

In the letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Authority has therefore encouraged consideration across municipalities, and possibly in collaboration with KL and KOMBIT, to prepare a joint impact assessment regarding the municipalities' processing of personal data in AULA.

The Data Protection Authority has additionally recommended that KL, in collaboration with the municipalities and possibly KOMBIT, consider the possibility of developing a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. The Data Protection Authority has noted that this consideration may also be relevant for other processing activities in the municipalities, where they use the same system for the same processing activities of the same types of personal data, which involve similar high risks.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection regulations. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to help comply with data protection regulations for the authorities that have adhered to the code. Although it facilitates compliance with the rules, it does not exempt the individual data controller from the obligations and tasks that rest with them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processes—for example, by using a system for other purposes.

"It is a significant and resource-intensive task for individual municipalities to conduct risk assessments and impact analyses that ensure the appropriate security measures. But it is necessary. AULA is a tool used in all municipalities for the same processing activities of the same type of personal data. We therefore encourage the municipalities—possibly in collaboration with KL and KOMBIT—to come together and ensure that citizens' information in AULA is sufficiently protected," says Signe Vestergård, special consultant at the Data Protection Authority.

1. Introduction

been significant delays in the preparation of the consequence analyses, which raises concerns regarding the timely identification and mitigation of risks associated with the processing of personal data in AULA.

1.4. Recommendations for further action

In light of the findings from the inspections, Datatilsynet recommends that all municipalities take immediate action to review and enhance their data protection measures in relation to AULA. This includes:

1. Conducting thorough risk assessments and consequence analyses that comply with the requirements set out in the General Data Protection Regulation (GDPR).
2. Implementing appropriate technical and organizational measures to ensure a high level of security for personal data processing.
3. Providing training and resources for all users of AULA, particularly those who may not have a primary role in data protection, to ensure they understand their responsibilities regarding personal data security.
4. Establishing clear protocols for the handling of personal data, including guidelines for communication and document sharing to prevent unauthorized disclosures.

Datatilsynet emphasizes the importance of ongoing monitoring and evaluation of data protection practices to adapt to any changes in the legal landscape or operational environment.

1.5. Conclusion

The inspections conducted by Datatilsynet have highlighted critical issues regarding the handling of personal data in AULA across the selected municipalities. It is essential for all municipalities to take these findings seriously and to implement the recommended actions to safeguard personal data and comply with the GDPR. Datatilsynet will continue to monitor the situation and provide guidance as necessary to ensure that data protection standards are upheld.

****Uncertainty Regarding Data Responsibility for Processing Personal Data in the Solution****

There has been uncertainty regarding where the data responsibility for the processing of personal data in the solution is placed. The municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data in AULA – and thereby also the responsibility for conducting risk assessments and impact assessments – was placed with KOMBIT. During the Data Protection Authority's inspection visit to KOMBIT in December 2019, the inspection found, as mentioned above, that KOMBIT is not to be regarded as the data controller. However, all three municipalities appear to have only prepared impact assessments long after there was clarity regarding the data responsibility for the processing of personal data in AULA. Two of the municipalities have even only prepared impact assessments after the inspection requested the material in connection with the initiation of the inspection, which is why the Data Protection Authority has expressed serious criticism towards these two municipalities. The Data Protection Authority has also expressed criticism towards the third municipality.

All five municipalities have furthermore received either criticism or serious criticism regarding the part of the cases that concerns the municipalities' risk assessment. The criticism relates to the documentation requirement in relation to being able to demonstrate that they have identified and mitigated the risks that the processing of personal data in AULA poses for the individuals to whom the data pertains, ensuring that an appropriate level of security is maintained. Additionally, the criticism concerns the lack of identification and implementation of relevant measures that should ensure an appropriate level of security.

Two of the municipalities have not submitted actual risk assessments, and the Data Protection Authority has expressed serious criticism towards both municipalities. One of the municipalities stated in January 2023 that they had not yet completed the preliminary work of identifying relevant measures that can be implemented to mitigate the identified high risks associated with the processing of personal data in AULA. The other municipality, instead of submitting a risk assessment, referred to a number of appendices as documentation for which mitigating measures the municipality had taken to reduce the risk for the registered individuals.

The other three municipalities have submitted risk assessments. The Data Protection Authority has expressed criticism towards these municipalities, as they have not sufficiently demonstrated that they have ensured an appropriate level of security.

Several municipalities have submitted material from KOMBIT, where a number of high risks associated with the use of AULA have been identified. The approach of the six municipalities to this material varies. Some municipalities have stated that they have adopted KOMBIT's risk assessment and have

subsequently based their descriptions of the measures they have implemented to mitigate these risks on it. One municipality states that it has reviewed the material from KOMBIT but concluded that it could not be immediately used as a basis for actual risk assessments. Other municipalities have conducted their own assessments, where some of the risks they have identified are assessed to pose a lower risk than what is indicated in KOMBIT's material – without sufficiently documenting the basis for this assessment.

****2. General Observations of the Data Protection Authority****

Based on the work with the inspection cases, the Data Protection Authority has made some general observations regarding the municipalities' work with the risks that the processing of personal data in AULA entails, and concerning certain data security matters.

****2.1. Clarification of Data Responsibility for New Solutions****

As stated in section 1.1 above, the Data Protection Authority could ascertain during the physical inspection visit to KOMBIT in December 2019 that KOMBIT was not to be regarded as the data controller for AULA, but that the individual municipalities were independently data controllers for their processing of personal data in AULA. The municipalities and KOMBIT had thus been of the opinion that the data responsibility for the processing of personal data in AULA – and thereby also the responsibility for conducting risk assessments and impact assessments – was placed with KOMBIT. The Data Protection Authority assumes that this uncertainty regarding data responsibility has been a reason why the municipalities have not prepared impact assessments prior to their implementation of AULA.

It is the Data Protection Authority's opinion that it is crucial to thoroughly consider at an early stage where the data responsibility for the processing of personal data in a new technical solution is placed. This is particularly important when developing or procuring solutions that will be used by several different organizations. In this regard, the inspection notes that all relevant stakeholders should be involved in the considerations – especially the organizations that will use the system.

Such clarification is essential for the data controllers to begin work on, for example, impact assessments and risk assessments, so that the required analyses and assessments are prepared before a new solution is put into use. The Data Protection Authority notes in this context that the purpose of an impact assessment is to determine the specific risks posed by the processing to the rights and freedoms of the data subjects and subsequently ensure that, before processing begins, measures are established to mitigate these risks and reduce the risk to a level that is less than high.

****2.2. Documentation of Assessments in Accordance with Article 32 and Article 5(1)(f)****

The Data Protection Authority has found in the inspection cases that the municipalities have handled the task of documenting their assessments regarding data security in various ways. Only three municipalities have prepared actual risk assessments, which they have submitted to the authority. One of the municipalities has instead referred to a number of appendices that the municipality has submitted to the supervisory authority as documentation for what mitigating measures the municipality has taken to reduce the risk for the registered individuals. Thus, the municipality has not submitted a proper risk assessment, which would indicate what risks the municipality has identified and what measures have been implemented to reduce these risks. Another municipality has referred to the risk assessment material from KOMBIT, where a number of risks have been identified, including several high risks. Following this, the municipality has stated that they had begun the work of identifying what measures could reduce these risks, but that the work is still ongoing. Some of the risk assessments conducted have been incorporated into the municipalities' impact assessments, while others have been separately prepared in Excel sheets, which the municipality refers to in their impact assessment. However, the Data Protection Authority has assessed in one of the supervisory cases that the relevant municipality had not identified and assessed the most significant risks that the processing of personal data in AULA poses for the registered individuals. Furthermore, the Data Protection Authority found in the three cases where the municipalities had submitted actual risk assessments that the municipalities

had not demonstrated that the measures implemented were sufficient to reduce the risk to be low (in two of the municipalities) and medium (in one of the municipalities). The Data Protection Authority assessed that the municipalities had not sufficiently demonstrated that they had ensured a level of security that matched the risks associated with the processing of personal data in AULA. The Data Protection Authority has generally reviewed the material from the municipalities with a focus on what risks they had identified, how they had assessed these risks, what measures they had described that were (or would be) implemented, and what effect they assessed the measures had on the risk. In this context, the Data Protection Authority has, among other things, looked at whether the municipality had addressed KOMBIT's assessment of the risk. The Data Protection Authority finds that the documentation obligation arising from the General Data Protection Regulation entails that material must be presented that documents how and on what basis the data protection considerations have been made, and what they have specifically led to. It should thus be clear what considerations, choices, and omissions have been made in order to ensure that the processing of the information is in accordance with the General Data Protection Regulation. In this connection, it must be possible to timestamp when and with what content relevant assessments and decisions have been made. This is a prerequisite for being able to ensure and oversee the legality of the processing and the ability to ensure compliance with the rights of the registered individuals, adherence to the data protection principles, and ensuring an appropriate level of security. It is the Data Protection Authority's opinion that a risk assessment should include an assessment of the consequence (e.g., high, medium, low) for the registered individuals in the event of loss of confidentiality, availability, and integrity. Subsequently, the risk assessment should identify what threats exist for the loss of confidentiality, availability, and integrity, as well as the likelihood (e.g., high, medium, low) that the threat will materialize. Finally, the risk assessment should map the existing security measures and their contribution to reducing the risk. On this basis, the data controllers can assess the risk and decide whether it is an acceptable risk or whether additional measures should be implemented. By addressing these elements in a risk assessment, the data controllers can thus document how they have assessed the risk for the registered individuals concerning the relevant processing activities, as well as on what basis they believe that the implemented measures have reduced the risk. As mentioned above in section 1.3, the risk assessment material from KOMBIT generally states that a number of processing activities carried out in AULA entail a high risk for the registered individuals. It is the Data Protection Authority's assessment that if a supplier, data processor, or available analyses establish or indicate specific risk scenarios, the data controllers should address these assessments. The Data Protection Authority can ascertain that several of the municipalities have not addressed these assessments in their risk assessment. Some of the municipalities' risk assessments even state that the processing of personal data in AULA does not involve high risks. The Data Protection Authority notes in this connection that the data controllers should at a minimum conduct a documented substantiated assessment that addresses why the issues identified in, for example, a supplier's assessment are not relevant to the data controller.

2.3. Risk of Misdelivery in AULA

It is generally the Data Protection Authority's opinion that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible to implement one or more technical measures to reduce the risk of misdelivery, or whether it is possible to design the messaging function in a way that minimizes such risk. Concurrently with the processing of the specific supervisory cases, the Data Protection Authority has also focused on what personal data breaches the municipalities report that relate to AULA. In this connection, the Data Protection Authority has found that a large portion of the reported breach concerns the erroneous transmission of personal data to one or more incorrect recipients in AULA. Several of the municipalities that were subject to supervision have, for the same reason, implemented organizational measures to make AULA's users aware of this risk when sending, among other things, messages via AULA. Additionally, one of the municipalities has also had a change request implemented, which the municipality had sent to KOMBIT, allowing for the deletion and editing of sent content in messages.

Despite this, the Data Protection Agency continues to receive a number of reports of breaches of personal data security from municipalities in general, concerning erroneous transmissions in AULA. In this context, the Data Protection Agency can mention that the supervision has found that AULA's messaging module is designed in such a way that in messages sent to multiple recipients, it is most obvious to reply to all persons in the message thread. There is a less visible field where it is possible to reply directly to the sender of the message. However, in the field where the user replies to all in the message thread, there is information about how many persons the user is replying to. Such a design of the messaging function entails, in the opinion of the Data Protection Agency, a risk that users of AULA inadvertently send a message to all recipients in a message thread instead of solely to the sender of the message. In this context, there is a risk that sensitive or confidential personal data is unlawfully disclosed to incorrect recipients.

Furthermore, the Data Protection Agency has found that recipient suggestions are automatically generated when the user begins to type in the recipient field "To". In this context, both employees, children, and parents are suggested as recipients. This entails, in the opinion of the Data Protection Agency, a risk that users select one or more incorrect recipients from the list of suggested recipients, or that they select, for example, all suggested parents whose first name or last name contains the entered letters, instead of one specific recipient.

2.4. Rights Management and Access Control

It is the opinion of the Data Protection Agency that the requirement for appropriate security in Article 32 of the Data Protection Regulation will generally imply that user access to systems is limited to the personal data necessary for the respective users' needs. The Data Protection Agency must note in this context that rights management in systems with personal data must prevent unauthorized access to personal data as well as unauthorized alteration or loss of personal data in the system in cases where users have access to change or delete information.

It is the opinion of the Data Protection Agency that in systems such as AULA, where a large number of confidential and protectable information about a large number of persons is processed, higher demands must be placed on the data controller's diligence in ensuring that unauthorized access to personal data does not occur.

Furthermore, it is the opinion of the Data Protection Agency that the requirement for appropriate security will generally imply that the data controller continuously checks whether access to systems and physical materials containing personal data is limited to users who have a legitimate need for access to the information.

According to Article 32, paragraph 1, letter d of the Data Protection Regulation, if relevant, procedures must be established for regular testing, assessment, and evaluation of the effectiveness of the technical and organizational measures to ensure processing security. Periodic control (audit) should, where appropriate, also include checks of authorizations and established accesses. It should be noted in this connection that a lack of periodic control (audit), in the opinion of the Data Protection Agency, entails an unnecessarily high risk that insufficient or inadequate access control is not identified in a timely manner.

Moreover, it is the opinion of the Data Protection Agency that the control of access rights should at a minimum consist of a verification of the work-related need at the time of allocation, a continuous check based on verification that this need is still present, and some form of auditing thereof. If the auditing is performed as random checks, the number and frequency of selected samples should be representative in relation to the number of possible incidents and the risk to the rights of the data subjects.

On this basis, it is the opinion of the Data Protection Agency that it is not sufficient for user accesses to AULA to be merely added and removed locally in the individual institutions and locally in the schools without subsequent periodic checks to determine whether the respective users still have a need for the access they have been granted.

3. Data Protection Agency Recommendations

3.1. Joint Impact Assessment and Code of Conduct

In system landscapes where multiple data controllers use the same systems and perform approximately the same processing of personal data, there can be significant synergy in conducting joint assessments regarding risk factors, potential impact assessments, and mitigating measures. The Data Protection Agency notes that it may be relevant to conduct a joint impact assessment if several data controllers plan to implement a common IT system or processing platform, for example, within the municipal sector. For multiple data controllers to collaborate on preparing a joint impact assessment, it is a prerequisite that it concerns the same type of system, the same processing activity of the same personal data, and that the processing activities involve similar high risks.

It is not crucial that there is full identity between the systems and processing activities, but that... the system, data, and in particular that the processing activities do not significantly differ from one another. Otherwise, a supplement to the joint impact assessment must necessarily be prepared.

It is thus the opinion of the Data Protection Authority that it would be sufficient for several municipalities to prepare one impact assessment regarding data protection for the processing of personal data in the same system, provided by the same supplier, if the same processing activities are carried out in the system, the same types of personal data are processed, and the processing activities involve the same high risks.[1]

It is the data controllers who specifically assess whether a joint impact assessment can be conducted for the processing activities in the systems. The data controllers in a joint impact assessment are each responsible for conducting the impact assessment.[2]

It is the opinion of the Data Protection Authority that, in relation to the municipalities' processing of personal data in AULA, the municipalities are using the same type of system for the same processing activities of the same types of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same supplier. The municipalities thus have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA.

The Data Protection Authority therefore encourages consideration across municipalities and possibly in collaboration with KL and KOMBIT to prepare a joint impact assessment regarding the municipalities' processing of personal data in AULA.

The Data Protection Authority has received KOMBIT's template for impact assessment from several municipalities, which pertains to the processing of personal data in AULA, and which may serve as a starting point for further work.

In associations and bodies representing categories of data controllers, it may also be beneficial to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation to specify the application of the General Data Protection Regulation.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities in order to comply with data protection rules. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to help comply with data protection rules for the authorities that have subscribed to the code. This facilitates compliance with the rules but does not relieve the individual data controller of the obligations and tasks that rest with them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processing, for example, by using a system for other purposes.

On this basis, the Data Protection Authority encourages consideration across municipalities and possibly in collaboration with KL and KOMBIT to develop a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. This may also be relevant to consider in relation to other processing activities in the

municipalities, where the municipalities use the same system for processing the same types of personal data for the same purposes.

3.2. Handling the risk of erroneous transmission in AULA

The Data Protection Authority additionally recommends that KOMBIT, together with the data-controlling municipalities, investigate whether it is possible to implement one or more technical measures to reduce the risk of erroneous transmission, or whether it is possible to design the messaging function in a way that reduces such risk.

[1] See also the Data Protection Authority's guidance on supervision of data processors from October 2021, which states, among other things, that several data controllers can jointly assess risks and examine similarities/differences in the use of the same data processor in order to decide whether a joint supervision of the data processor can be conducted.

[2] Reference is made to the Data Protection Authority's guidance on impact assessment from March 2018.